Report di analisi del link sospetto – DNS_Changer.ps1

Introduzione

In seguito alla segnalazione da parte di un utente di comportamenti anomali sul proprio computer, il team CSIRT/SOC ha analizzato il link sospetto fornito utilizzando la piattaforma di sandbox ANY.RUN.
L'obiettivo dell'analisi è identificare eventuali attività malevole, verificare la presenza di malware e valutare il livello di rischio per l'infrastruttura aziendale; l'analisi è stata effettuata in un ambiente controllato Windows 7 a 32 bit, consentendo di osservare il comportamento del sistema durante l'esecuzione del file sospetto.

Analisi del comportamento del file

L'analisi ha evidenziato che il link reindirizza al download e all'esecuzione di uno script PowerShell denominato DNS_Changer.ps1, questo script è stato scaricato da un server remoto ospitato su GitHub: https://gist.github.com/chinmay-sh/.../DNS_Changer.ps1
Una volta scaricato, il file è stato eseguito automaticamente tramite il processo:
powershell.exe -NoProfile -ExecutionPolicy Bypass -File DNS_Changer.ps1
Questo comando indica chiaramente che il malware utilizza il parametro -ExecutionPolicy Bypass per bypassare le protezioni di sicurezza di Windows, consentendo l'esecuzione di codice non autorizzato.
Il processo powershell.exe è stato eseguito con privilegi elevati e ha avviato operazioni sospette, tra cui l'esecuzione di script PowerShell malevoli, il bypass delle protezioni di sicurezza, l'accesso alle impostazioni di sistema e di rete e la modifica delle configurazioni del sistema, questi comportamenti sono tipici di malware progettati per compromettere il sistema e alterarne la configurazione.

Attività di rete sospette

Durante l'esecuzione, il sistema ha stabilito connessioni di rete verso server esterni, tra cui gist.github.com (IP: 140.82.121.4), identificato come sospetto e malevolo, dal quale è stato scaricato lo script originale. Sono state inoltre rilevate 22 connessioni TCP/UDP attive e 58 richieste DNS verso domini esterni, confermando che il sistema compromesso comunica attivamente con server remoti controllati dall'attaccante.
La funzione principale del malware consiste nella modifica dei server DNS del sistema, sostituendo quelli legittimi con server malevoli controllati dall'attaccante ai seguenti indirizzi IP: 94.140.15.14, 94.140.15.15 e 94.140.15.16.
Questo consente all'attaccante di reindirizzare tutto il traffico di rete della vittima verso siti di phishing o di intercettare le comunicazioni tramite attacco Man-in-the-Middle, il tutto in modo completamente trasparente per l'utente.

Tecniche utilizzate dal malware (MITRE ATT&CK)

L'analisi ha identificato 3 tattiche e 4 tecniche mappate sulla matrice MITRE ATT&CK, con 29 eventi totali rilevati.

Le tecniche identificate sono Command and Scripting Interpreter (PowerShell) nella categoria Execution, Create Account (Local Account) nella categoria Persistence, User Execution tramite Malicious File, e Query Registry nella categoria Discovery.

Indicatori di compromissione (IOC)

Sono stati identificati i seguenti indicatori di compromissione:

- File malevolo: DNS_Changer.ps1
- Processi sospetti: powershell.exe -NoProfile -ExecutionPolicy Bypass
- Dominio sospetto: gist.github.com (IP: 140.82.121.4)
- Server DNS malevoli: 94.140.15.14, 94.140.15.15, 94.140.15.16
- SHA256: 3B9E727C56BFA9A16E5311F8D17472B9DCBE2F1E149FA2924EDA013611076D39
- MD5: 7CD193E2B99F15030CA538B924B4498C

Valutazione della minaccia

L'analisi conferma che il file DNS_Changer.ps1 è uno script malevolo progettato per compromettere il sistema tramite PowerShell, bypassando le protezioni di sicurezza di Windows.

In particolare, lo script modifica i server DNS del sistema sostituendoli con server malevoli controllati dall'attaccante, consentendo il reindirizzamento del traffico di rete verso siti di phishing o l'intercettazione delle comunicazioni.

Il malware è inoltre in grado di creare account locali per garantirsi la persistenza sul sistema e di comunicare con server esterni per ricevere ulteriori istruzioni. Questo rappresenta una minaccia significativa per la sicurezza dell'infrastruttura aziendale.

Raccomandazioni

A seguito dell'analisi, si raccomanda di adottare immediatamente le seguenti misure: isolare la macchina compromessa dalla rete aziendale per impedire la propagazione dell'attacco, ripristinare le configurazioni DNS originali sui sistemi potenzialmente interessati, bloccare a livello di firewall gli indirizzi IP malevoli identificati (94.140.15.14, 94.140.15.15, 94.140.15.16), analizzare gli altri sistemi della rete per verificare la presenza dello stesso script e procedere con un'analisi forense completa della macchina compromessa per identificare eventuali ulteriori componenti malevoli installati.

Report di analisi del link sospetto – Remcos RAT

Introduzione

In seguito alla segnalazione di comportamenti anomali da parte di un secondo utente, il team CSIRT/SOC ha analizzato il link sospetto utilizzando la piattaforma di sandbox ANY.RUN.
L'obiettivo dell'analisi è identificare eventuali attività malevole, verificare la presenza di malware e valutare il livello di compromissione del sistema. L'analisi è stata effettuata in un ambiente controllato Windows 7 Professional a 32 bit, consentendo l'osservazione completa del comportamento del file eseguito.

Analisi del comportamento del file

L'analisi ha evidenziato che il link scarica un file eseguibile denominato *DOCX_SENTENCIA_20230003001.exe*, distribuito tramite Google Drive, tecnica comunemente utilizzata per aggirare i controlli di sicurezza perimetrali poiché il traffico verso i servizi Google è generalmente considerato affidabile dai firewall aziendali. Il file si presenta come un documento Adobe Acrobat legittimo (versione 23.1.20174.0), ma è in realtà un eseguibile malevolo.
Una volta eseguito con privilegi elevati (Integrity Level: HIGH), il malware ha avviato una serie di processi sospetti.
Tramite cmd.exe ha eseguito comandi di sistema, tramite csc.exe (compilatore Visual C#) ha compilato ed eseguito codice malevolo direttamente in memoria, e tramite schtasks.exe ha creato attività pianificate per garantirsi la persistenza.
Il malware si è copiato nel seguente percorso:
C:\Users\admin\AppData\Roaming\AppData\AppData.exe
Successivamente ha creato un'attività pianificata denominata "Nano" per eseguirsi automaticamente ogni 10 minuti:
schtasks /create /sc minute /mo 10 /tn "Nano" /tr "AppData.exe"
Questo comportamento garantisce la persistenza del malware nel sistema anche dopo un riavvio.

Identificazione del malware

L'analisi ha confermato la presenza del malware **Remcos RAT**, classificato da ANY.RUN come **Malicious Activity**, il livello di gravità più alto. Le minacce identificate sono un **Remote Access Trojan (RAT)** e un **Keylogger**. Remcos è un noto strumento di accesso remoto utilizzato dagli attaccanti per ottenere il controllo completo dei sistemi compromessi. Una volta installato, il malware è in grado di registrare tutti i tasti premuti dall'utente tramite keylogging, eseguire comandi remoti sul sistema, raccogliere informazioni sensibili come credenziali e dati personali, e controllare il sistema da remoto in modo completamente

trasparente per la vittima. Durante l'analisi sono stati rilevati in totale 138 processi, di cui 7 classificati come malevoli e 1 sospetto.

Attività di rete e Command and Control

Durante l'esecuzione, il malware ha stabilito connessioni di rete sospette verso server di Command and Control (C2). Sono state rilevate 82 connessioni TCP/UDP e 36 richieste DNS. La connessione malevola è stata identificata tramite la firma **JA3 Hash di Remcos 3.x** su protocollo TLS, confermando la comunicazione cifrata con il server C2 dell'attaccante. Tra le minacce di rete rilevate figurano anche attività di DNS Redirection tramite il dominio con-ip.com, classificato come "Potentially Bad Traffic". Questo consente all'attaccante di controllare il sistema da remoto, eseguire comandi arbitrari ed esfiltrare dati sensibili.

Tecniche utilizzate dal malware (MITRE ATT&CK)

L'analisi ha identificato tecniche mappate sulla matrice MITRE ATT&CK. Nella categoria Execution è stato rilevato l'utilizzo di Command and Scripting Interpreter tramite Visual C# Compiler. Nella categoria Persistence è stata identificata la creazione di attività pianificate tramite Task Scheduler. Nella categoria Defense Evasion il malware tenta di mascherarsi da applicazione legittima (Adobe Acrobat). Nella categoria Collection e C&C il keylogger salva i log localmente e comunica con il server remoto tramite connessione TLS cifrata.

Indicatori di compromissione (IOC)

Sono stati identificati i seguenti indicatori di compromissione:
- File malevolo: DOCX_SENTENCIA_20230003001.exe
- File installato per persistenza: C:\Users\admin\AppData\Roaming\AppData\AppData.exe
- Task pianificato malevolo: Nano (esecuzione ogni 10 minuti)
- Processi sospetti: cmd.exe, csc.exe, schtasks.exe
- Malware identificato: Remcos RAT, Keylogger
- SHA256:B24023DF44B0A1074B5DBB86AE6DA16FA4C10918C5C21E0100C4812CAE056C49
- MD5: F227B42BC5D29AC82A82C40B6325B9E3

Valutazione della minaccia

L'analisi ha confermato la presenza di un Remote Access Trojan (Remcos RAT), classificato come attività malevola. A differenza del primo caso, che comprometteva le sole impostazioni DNS, questo malware garantisce all'attaccante il controllo remoto completo del sistema, con capacità di keylogging, furto di credenziali e persistenza garantita tramite task pianificato. Il sistema deve essere considerato completamente compromesso e la gravità della minaccia è da ritenersi critica per la sicurezza dell'infrastruttura aziendale.

Raccomandazioni

A seguito dell'analisi, il team CSIRT/SOC raccomanda di isolare immediatamente il sistema compromesso dalla rete aziendale, eliminare il task pianificato "Nano" e il file AppData.exe, modificare tutte le credenziali utilizzate sul sistema in quanto potenzialmente esfiltrate tramite keylogger, eseguire una reinstallazione completa del sistema operativo data la profondità della compromissione, monitorare il traffico di rete aziendale per individuare eventuali ulteriori comunicazioni verso server C2 e verificare se altri sistemi della rete abbiano scaricato lo stesso file da Google Drive.

CONCLUSIONE

L'analisi dei due link sospetti ha confermato che entrambi gli utenti sono stati vittime di attacchi distinti ma complementari.

Il primo caso ha evidenziato la presenza di uno script PowerShell malevolo (DNS_Changer.ps1) progettato per modificare le impostazioni DNS del sistema, reindirizzando il traffico di rete verso server controllati dall'attaccante e rendendo possibili attacchi di tipo Man-in-the-Middle e campagne di phishing mirate.

Il secondo caso ha rivelato una compromissione ben più grave, con l'installazione di un Remote Access Trojan (Remcos RAT) dotato di capacità di keylogging, che ha garantito all'attaccante il controllo remoto completo del sistema e la possibilità di esfiltrare credenziali e dati sensibili.

La combinazione dei due attacchi suggerisce uno scenario particolarmente pericoloso per l'infrastruttura aziendale: il DNS hijacking del primo caso potrebbe essere stato sfruttato per facilitare la distribuzione del secondo malware, reindirizzando l'utente verso risorse malevole.

Entrambi i sistemi devono essere considerati completamente compromessi e si raccomanda di adottare immediatamente le misure di contenimento, isolamento e ripristino descritte nei rispettivi report.